

SCRAM Analysis

Analyze SCRAM (Write a simple pdf document):

- a. Which parts of SCRAM provide “client authentication”?
- b. Which parts of SCRAM provide “server authentication”?
- c. If we do not use TLS to protect SCRAM, then which parts may cause offline dictionary attacks?

Client Authentication

The client computes the $\text{Salted_pw} = H^n(r, pw)$. Only a legitimate client with the correct password can compute this hash. This proves the client knows the password without transmitting it.

In addition the client computes client_proof and send it over. The server verifies then the client_proof . The ServerChallenge prevents replay attacks by ensuring freshness

Server Authentication

Only a legitimate server can compute the Server_sign , because it has access to the Salted_pw , r and n , which is then send to the client and verified by the client. This also proves that the server knows the required parameters without transmitting them. The ClientChallenge prevents replay attacks by ensuring freshness

SCRAM without TLS

First of all if we remove TLS from the SCRAM protocol then all other messages like ClientFirst , ServerFirst and further are not encrypted and transmitted in plaintext, which is a big problem, because adversaries will gather these information and gains informations about $ch_1 || ch_2, r, n$.

The adversary can now perform offline attacks to guess the password. It can compute the password, because it got r and n .

An adversary could also intercept Client_proof and the ServerFirst messages. With the help of these two messages the adversary can compute Server_sign

Also a Man-in-the-Middle Attack can be performed easily, because all the messages are sent in plaintext.

Overall SCRAM without TLS does not provide security. TLS prevents eavesdropping of $r, n, \text{Client_proof}$ and Server_sign . TLS_INFO prevents Man-in-the-Middle Attacks and forward secrecy is provided.